

Sistemas Distribuídos e Computação em Nuvem

Aula 16 — Segurança, privacidade e LGPD

C3 ·  Estudo Dirigido (EAD) · véspera do ENADE

Prof. M.Sc. Howard Cruz Roatti · FAESA · 2026/2

Como funciona este Estudo Dirigido (EAD)

Aula **assíncrona**. Siga nesta ordem:

1. **Leia** os conceitos de segurança (criptografia, TLS, autenticação/autorização, LGPD).
2. **Faça o roteiro guiado** — proteger a plataforma (JWT, HTTPS, logs limpos).
3. **Resolva o simulado ENADE** (corrigido no início da próxima aula).
4. **Conclua o C3.A2** — completo, **seguro** e documentado.

 **O ENADE é no próximo domingo (29/11).** A revisão do fim deste material é parte essencial do EAD.

Objetivos desta aula

Ao final, você será capaz de:

1. **Explicar** criptografia (simétrica/assimétrica/hash) e o papel do **TLS/HTTPS**.
2. **Diferenciar autenticação** de **autorização** e usar **JWT** no gateway.
3. **Aplicar** princípios da **LGPD** no pipeline de IA (minimização, anonimização).

Criptografia — o essencial

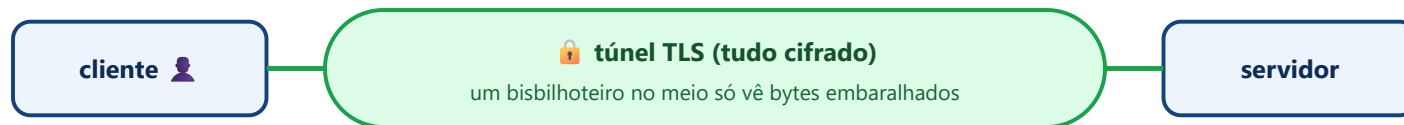
- **Simétrica:** **uma** chave secreta cifra e decifra. Rápida; o desafio é **compartilhar** a chave.
- **Assimétrica:** um **par** (pública + privada). Cifra-se com a pública, só a privada decifra (e vice-versa p/ assinar).
- **Hash:** resumo **de mão única** (senhas, integridade). Não "descriptografa".



💡 **Em miúdos:** simétrica = **cadeado com uma chave** (os dois lados têm cópia); assimétrica = **caixa de correio** (qualquer um deposita pela fenda pública; só o dono abre); hash = **triturar o papel** (não dá para recompor).

TLS/HTTPS — o cadeado do transporte

O **HTTPS** é o HTTP **dentro de um túnel TLS**: o que trafega entre o cliente e o servidor vai **cifrado**, protegido contra **escuta** e **adulteração** no caminho.



HTTP puro = cartão-postal (todos leem) · HTTPS = carta lacrada

💡 Na nuvem, o provedor (Render/Railway) normalmente já entrega **HTTPS** no domínio. Nunca envie token ou senha por **HTTP puro**.

Autenticação × autorização (e o JWT)

- **Autenticação (quem é você?):** provar a identidade (login/senha, token).
- **Autorização (o que você pode?):** quais ações/recursos aquele usuário tem permissão.

Autenticação

a portaria confere o documento 

Autorização

o crachá diz quais andares você acessa 

💡 O **JWT** resolve os dois: após o login, o servidor emite um token **assinado** que o cliente manda a cada requisição. Dentro dele vão a identidade (`sub`) e permissões (`role`).

Como um JWT funciona

Três partes: `header.payload.assinatura`. A assinatura é um **HMAC** de `header.payload` com um **segredo** que só o servidor tem.

```
eyJhbGciOiJIUzI1NiJ9 . eyJzdWIiOiJhbHVubzQyIiwicm9sZSI6ImFsdW5vIn0 . aptC20KH...  
  └ header (alg)      └ payload (sub, role, exp)          └ assinatura
```

- **Adulterar** o payload (ex.: `role: admin`) **quebra** a assinatura → o servidor **rejeita**.
- O payload é só **codificado** (base64), **não** cifrado: **nunca** coloque segredo nele.

💡 O `auth_demo.py` cria um JWT real (HS256) e mostra os 4 casos: válido, adulterado, segredo errado e expirado.

LGPD no pipeline de IA

A **LGPD** rege o tratamento de **dados pessoais**. No seu serviço de IA:

- **Minimização:** só colete/envie o **necessário**. **Não** mande dados pessoais (CPF, nome, e-mail) ao **LLM** se não precisa.
- **Anonimização:** remova/masque identificadores antes de processar.
- **Finalidade e consentimento:** use o dado só para o fim informado; registre a base legal.
- **Segurança:** cifrar em trânsito (TLS) e em repouso; **logs sem** dados sensíveis.

⚠ Risco clássico: **logar o prompt inteiro** do usuário (com dados pessoais) ou **enviar PII** para uma API de LLM de terceiros sem necessidade. Minimize.

Roteiro guiado

Proteger a plataforma — JWT, HTTPS e logs limpos

Mão na massa — siga o Guia do Laboratório

Roteiro em **4 missões**: entender o JWT no aquecimento, **proteger o gateway com JWT**, **garantir HTTPS e logs limpos (LGPD)** e **fechar o C3.A2**.

👉 **Abrir o Guia do Laboratório »**

no índice do site: Aula 16 → [Guia do Lab](#)

💡 Aquecimento pronto e testado: `exemplos/aula16/auth_demo.py` — JWT HS256 em Python puro (criar, verificar, detectar adulteração).

O que o exemplo mostra (aquecimento)

```
python auth_demo.py
# 1) token valido: OK -> {'sub': 'aluno42', 'role': 'aluno', ...}
# 2) payload adulterado (role=admin): REJEITADO -> assinatura invalida
# 3) segredo errado: REJEITADO -> assinatura invalida
# 4) token expirado: REJEITADO -> token expirado
```

💡 É a garantia de integridade: sem o **segredo**, ninguém forja nem altera um token sem ser pego.

Revisão para o ENADE — o semestre em uma página

C1 · Comunicação

Falha parcial · socket · **TCP/UDP** · thread/corrida · **gRPC/.proto** · **REST**/status/idempotência · IA como serviço.

C2 · Coordenação

Fila/assíncrono · **Lamport**/vetorial · **CAP** (CP×AP) · **Raft**/quórum · resiliência (timeout/retry/**disjuntor**).

C3 · Nuvem e segurança

IaaS/PaaS/SaaS · **container**/imagem · elasticidade · orquestração · **serverless**/cold start · **observabilidade** (log/métrica/**trace**) · **TLS/JWT**/LGPD.

💡 Releia os quadros **Foco ENADE** de cada aula.
É o melhor resumo possível.

No seu trabalho — C3.A2

- **Proteja o gateway** com **JWT**: rota de login emite o token; rotas sensíveis exigem `Authorization: Bearer <token>`.
- **HTTPS** ativo (o provedor de nuvem entrega) e **logs limpos** (sem dados pessoais).
- **LGPD**: minimize o que vai ao LLM; documente a base legal no README.

💡 Puxa para o kit: adicione o middleware de JWT no gateway e um teste simples — requisição sem token recebe **401**; com token válido, passa.

Atividade para casa

1. **Proteja** o gateway do **C3.A2** com **JWT** (login + rotas protegidas).
2. **Garanta HTTPS** no deploy e **remova dados sensíveis** dos logs.
3. **Resolva o simulado ENADE** e **conclua o C3.A2** (completo, seguro, documentado).

📌 **Entregar até a Aula 17 (prova C3.A1):** o C3.A2 completo, com JWT, HTTPS e notas de LGPD no README + o simulado ENADE resolvido. Roteiro no **Guia do Laboratório**.

◆ Foco ENADE

O que costuma cair:

- **Criptografia** simétrica × assimétrica; **hash**; **TLS/HTTPS**.
- **Autenticação** × **autorização**; **JWT** (assinado, não cifrado).
- **LGPD**: minimização, anonimização, finalidade, segurança.
- Boas práticas: segredo fora do código, logs sem PII.

Termos-chave: Criptografia · TLS/HTTPS · Autenticação · Autorização · JWT · LGPD · Minimização

💡 Pegadinha: achar que o payload do JWT é secreto. Ele é só **codificado** (base64) — qualquer um lê; a proteção é a **assinatura**.

Questão de autoavaliação (estilo ENADE)

Um desenvolvedor afirma que pode guardar a **senha do usuário** dentro do **payload de um JWT**, pois "o token é seguro". Sobre essa afirmação, é correto dizer que:

- A) está certo, pois o JWT é totalmente cifrado
- B) está errado: o payload do JWT é apenas codificado (base64) e pode ser lido por qualquer um; a assinatura garante integridade, não sigilo**
- C) está certo, desde que o token expire
- D) está errado, pois o JWT não permite campos personalizados
- E) está certo, pois o HTTPS já protege tudo

Resolução — alternativa B

- O **payload** do JWT é **base64** (reversível) — **não** é cifrado. Qualquer um que receba o token **lê** o conteúdo.
- A assinatura garante **integridade/autenticidade** (não foi adulterado), **não sigilo**. Logo, **nunca** coloque senha/segredo no payload.

💡 É exatamente o que o `auth_demo.py` evidencia: o payload é legível; o que protege é a assinatura com o segredo do servidor.

Fora da sala · Glossário

Para estudar

- **Coulouris**, cap. 11 — Segurança.
- Texto da **LGPD** (art. 6º — princípios) — leitura dirigida.
- Decodifique o token do `auth_demo.py` em **jwt.io** e veja o payload legível.

Glossário

- **Simétrica/assimétrica**: criptografia com uma chave / par de chaves.
- **Hash**: resumo de mão única.
- **TLS/HTTPS**: criptografia do transporte.
- **Autenticação/autorização**: quem é você / o que pode.
- **JWT**: token assinado (header.payload.assinatura).
- **LGPD**: lei de proteção de dados pessoais.

Bons estudos!

Proteja o C3.A2 (JWT + HTTPS + LGPD), resolva o simulado e **arrase no ENADE**.

Próxima (Aula 17): Revisão e Avaliação C3.A1 + entrega do C3.A2 — o semestre inteiro em uma página e a prova final do ciclo.

← Anterior

Aula 15 · Observabilidade

≡ Índice

todas as aulas